LEARNER ATTACHMENT

First-Line Cybersecurity Response Procedure

Training SOP FLR-01 | Suspected phishing and identity compromise | Version 1.0

AUTHORITY Tier 1 performs only actions explicitly authorized by this training procedure and the organization's production SOP. If production authority differs, the production SOP controls.

Entry criteria

- A workforce member reports selecting a suspicious link, entering credentials, approving an unexpected MFA prompt, or observing unexpected account activity.
- A Microsoft security signal indicates a risky sign-in, suspicious message, or identity-related incident.
- Possible ePHI access is reported or indicated by a data or audit signal.

Three first-line actions

Action	Required execution	Record
1. Isolate / contain	Open the incident; stop further user interaction with the message. Invoke the pre-approved identity containment workflow or immediately engage SOC/IAM. Account disablement, session revocation, password reset, and risk confirmation require the authorized role and business-continuity check.	Actor, action, timestamp, SOP criterion, action result
2. Preserve evidence	Preserve the original message by message ID or approved submission; retain incident/alert IDs, sign-in and risk records, relevant audit events, user statement, and timestamps. Do not delete, edit, annotate, or forward the original evidence through an unapproved channel.	Evidence ID, source, time range, repository, integrity note
3. Escalate	Warm-transfer to the SOC with cited signals and the specific investigation or containment action requested. Add IAM, information-governance, audit, and privacy tasks only when their documented trigger is met.	Destination, channel, transfer time, acknowledgment

Safety and care-continuity checks

- Do not delay active-risk containment solely to collect a perfect evidence set.
- Tell the clinician how to obtain approved downtime or alternate access; do not create a shared emergency account.
- Do not ask the user to reopen the suspicious link or reproduce PHI in the ticket.
- Do not mark a risk as safe or compromised unless the assigned responder has completed the required investigation.

Exit criteria

- SOC or designated responder has accepted ownership.
- Authorized containment status is recorded.
- Evidence references and timestamps are preserved in the restricted incident record.
- Possible ePHI involvement has been routed under PRIV-01 when applicable.

Authoritative sources

- HHS - Summary of the HIPAA Security Rule
- Microsoft - Compromised identity incident response SOP template
- Microsoft - Phishing investigation playbook
- Microsoft Entra - Investigate identity risk
- Microsoft Entra - Least privileged roles by task